Lead Creation Requests Can Bypass Duplicate Detection – Server Side Validation Missing

Severity: Medium

CVSS Score: 5.6 (Medium)

CWE

- CWE-602: Client-Side Enforcement of Server-Side Security
- CWE-799: Improper Control of Interaction Frequency (related)
- CWE-841: Improper Enforcement of Behavioral Workflow

Affected Asset

- URL: https://crm-stage.crusource.com
- Endpoint: POST /api/v1/leads
- Environment: Staging
- Date Discovered: 14-10-2026

Why this is a vulnerability:

- The CRM application implements a duplicate-lead detection mechanism that operates exclusively in the client-side UI. When a user attempts to create a lead with details matching an existing record, the frontend displays a popup warning the user that a duplicate exists and offers an option to proceed anyway.
- This control is **not enforced on the server**. When the original POST /api/v1/leads request is captured and replayed directly through Burp Suite (or any HTTP client), the server accepts it unconditionally and creates a new record — without duplicate detection, validation, or rejection.
- The result is that the duplicate-detection control can be bypassed by any user who can intercept or script HTTP requests. The server performs no independent verification of the business rule and relies entirely on the browser to prevent duplicates.
- This is a classic example of **client-side enforcement of a server-side rule**. Business logic affecting data integrity must be enforced on the server, regardless of what the UI does.
- Duplicate Leads Are Fully Operable. Both the original and duplicated lead records accept edit, assign, convert, and delete operations independently. Neither is flagged as suspicious or linked to the other.

Delivery vector (how an attacker would exploit it):

- **Replay the Original Request:** A user creates a lead normally. They capture the POST /api/v1/leads request in Burp Suite or browser DevTools. Replaying the same request with the same body creates an additional identical lead — no popup, no warning, no rejection.
- **Automate Duplication:** Because the server imposes no deduplication and no rate limiting, an attacker (or a misconfigured integration) can replay the request repeatedly, flooding the CRM with duplicate lead records.
- **Data Integrity Impact:** Duplicate leads persist as first-class records with unique internal IDs. They are independently operable — they can be edited, assigned, converted, and deleted separately. Reporting, pipeline analytics, and lead-scoring algorithms become unreliable as the same prospect appears multiple times.
- **Business Logic Impact:** If the CRM is licensed, metered, or billed by record count, automated duplication can create artificial cost or consume quota. Integrations (email tools, dialers, marketing automation) that sync from the CRM will pull duplicates into downstream systems.
- **Lower Likelihood, Higher Impact:** A malicious insider, a compromised integration, or a low-privileged user with API access could silently corrupt the tenant's lead database over time. Because duplicates appear as legitimate records, detection without manual review is difficult.

Remediation recommendation

1. **Enforce duplicate detection on the server.** Before creating a new lead, query the database for an existing record matching the uniqueness key (e.g., email, phone, or a composite of name + company). Return 409 Conflict with the existing record's ID if a match is found.
2. **Require explicit confirmation for legitimate overrides.** If "create anyway" is a supported workflow, the server must require a dedicated confirmation parameter that the UI sets only after user interaction — for example, POST /api/v1/leads with "confirm_duplicate": true. Never rely on the UI to enforce this.
3. **Add idempotency keys.** For all create endpoints, accept a client-supplied Idempotency-Key header. Cache successful responses keyed by that value for a short window (e.g., 24 hours) and return the original response if the same key is reused. This blocks replay-style duplication regardless of payload content.
4. **Reconcile existing duplicates.** Audit the current lead database for accidental or malicious duplicates and provide an admin-side merge tool. Deleting duplicates silently may destroy attached notes, activities, or history.
5. **Log and alert on anomalous create volume.** Emit a security event when a single user or API key creates an unusually high number of leads in a short window; alert tenant administrators.

Summary

The duplicate-detection popup shown when a user attempts to create an existing lead is a UI-only control with no corresponding server-side check. By capturing the original POST /api/v1/leads request and replaying it via Burp Suite, a duplicate lead is created with no warning, no rejection, and no client-side popup – and both records persist as fully independent, operable entities. Because the server performs neither deduplication nor rate limiting on the create endpoint, an attacker or a buggy integration can generate unlimited duplicate leads, corrupting reporting, pipeline analytics, licensing quotas, and any downstream system that syncs from the CRM. Remediation requires enforcing duplicate detection server-side, returning 409 Conflict on matched records, requiring an explicit override parameter for legitimate duplicates, and adding idempotency keys and rate limiting to create endpoints. The absence of rate limiting was not actively tested due to scope restrictions on availability testing, but was observed as a configuration weakness during normal use.